

IT-Sicherheit

Prof. Dr. Johannes Freudenmann (DHBW Karlsruhe)
Masterprogramm Informatik

www.dhbw.de

Überblick

- Vorstellung der Vulnerabilities (<https://nvd.nist.gov/general/nvd-dashboard>, CVEs, s. Kollege Straub)
- Sicherheitsmechanismen in Betriebssystemen
 - Passworte (Ergänzung rainbowtables), ACL
- System Hardening (Empfehlungen)
 - CIS Security Benchmarks
 - NIST CCE (analog zu CVE, aber nicht zeitnah gepflegt)
- Security Engineering (Eckert Kap. 4) -> Straub
 - Überblick, Bedrohung STRIDE, Risiko DREAD
- Bewertung der IT-Sicherheit (Eckert Kap. 5)
 - CC – Common Criteria ISO 15408 TUM 7/22-34
- Überprüfung der Sicherheit – Penetration Testing
 - OpenVAS

CIS Company

- CIS – Center for Internet Security (www.cisecurity.org/)
nonprofit organization focused on enhancing the cyber security
- CIS Security Benchmarks Division
cost-effective, internationally recognized solutions
to improve cyber security
 - Members: Commercial; Government; Academic
Siemens, O2, SWIFT, Berkeley, NASA, NIST, HP, IBM, Symantec...
 - CIS Benchmarks: best practice secure configuration
 - globally used, de facto user-originated standard
 - freely available for download in PDF format.
 - Security Metrics: eigenen Status messen
 - CIS-CAT Security Assessment Tool
Übereinstimmung mit Benchmarks prüfen

CIS Benchmarks

- Diverse Betriebssysteme und Anwendungen
 - Apple iOS/OSX, Windows, Linux, Android, VMWare, Xen
 - Checkpoint, Cisco
 - Kerberos, Radius
 - Opera, Firefox, IE
 - MySQL, DB2, Oracle
 - IIS, Apache
 - Cloud Provider
 - ...

CIS Benchmarks

- Scoring Information

A scoring status indicates whether compliance with the given recommendation impacts the assessed target's benchmark score.

- Scored

Failure to comply with "Scored" recommendations will decrease the final benchmark score. Compliance with "Scored" recommendations will increase the final benchmark score.

- Not Scored

Failure to comply with "Not Scored" recommendations will not decrease the final benchmark score. Compliance with "Not Scored" recommendations will not increase the final benchmark score.

CIS Security Profiles

Profile Definitions

- Level 1

Items in this profile intend to:

- be practical and prudent;
- provide a clear security benefit; and
- not inhibit the utility of the technology beyond acceptable means.

- Level 2

This profile extends the "Level 1" profile. Items in this profile exhibit one or more of the following characteristics:

- are intended for environments or use cases where security is paramount
- acts as defense in depth measure
- may negatively inhibit the utility or performance of the technology

CIS Benchmark Bsp. Windows 10

- *1.1.4 (L1) Ensure 'Minimum password length' is set to '14 or more character(s)' (Scored)*
- **Profile Applicability:**
Level 1 (L1) - Corporate/Enterprise Environment
- **Description:** This policy setting determines the least number of characters that make up a password for a user account. There are many different theories about how to determine the best password length for an organization, but perhaps "pass phrase" is a better term than "password." In Microsoft Windows 2000 and newer, pass phrases can be quite long and can include spaces. Therefore, a phrase such as "I want to drink a \$5 milkshake" is a valid pass phrase; it is a considerably stronger password than an 8 or 10 character string of random numbers and letters, and yet is easier to remember. Users must be educated about the proper selection and maintenance of passwords, especially with regard to password length. The recommended state for this setting is: **14 or more character(s)**

CIS Benchmark Bsp. Windows 10

- **Rationale:**

Types of password attacks include dictionary attacks (which attempt to use common words and phrases) and brute force attacks (which try every possible combination of characters). Also, attackers sometimes try to obtain the account database so they can use tools to discover the accounts and passwords.

- **Audit:**

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

- **Remediation:**

To establish the recommended configuration via GP, set the following UI path to 14 or more character(s):

CIS Benchmark Bsp. Windows 10

- **Impact:** Requirements for extremely long passwords can actually decrease the security of an organization, because users might leave the information in an insecure location or lose it. If very long passwords are required, mistyped passwords could cause account lockouts and increase the volume of help desk calls. If your organization has issues with forgotten passwords due to password length requirements, consider teaching your users about passphrases, which are often easier to remember and, due to the larger number of character combinations, much harder to discover.
- **Note:** Older versions of Windows such as Windows 98 and Windows NT 4.0 do not support passwords that are longer than 14 characters. Computers that run these older operating systems are unable to authenticate with computers or domains that use accounts that require long passwords.
- **Default Value:** 7 characters on domain members. 0 characters on stand-alone workstations.
- **References:** 1. CCE-33789-9

CIS Benchmark

- Aktuelle Beispiele
 - Windows 11
 - Docker
 - Apache Tomcat
 - Apple iOS 26
 - Google Android

CCE Common Configuration Enumeration

- Erstellt von MITRE (Wurzel: MIT Research, heute US-weit)
- Seit 30 Mai 2013 bei US-NIST
 - **<https://nvd.nist.gov/config/cce/index>.**
- Format: Excel und XML.
- Aktuell Version 5, 2/2013, 4/2021, 7/2022 und 12/2025
- Server und Clients
 - Apache, Exchange, Windows Server, IIS
 - MS Office, Windows
 - Letzter Update iOS, macOS
- Beispiel Apache httpd 2.2, 176 Einträge.
- Wird von NIST wohl nicht sehr gut gepflegt.

- Bewertung der IT-Sicherheit

Bewertung der IT-Sicherheit

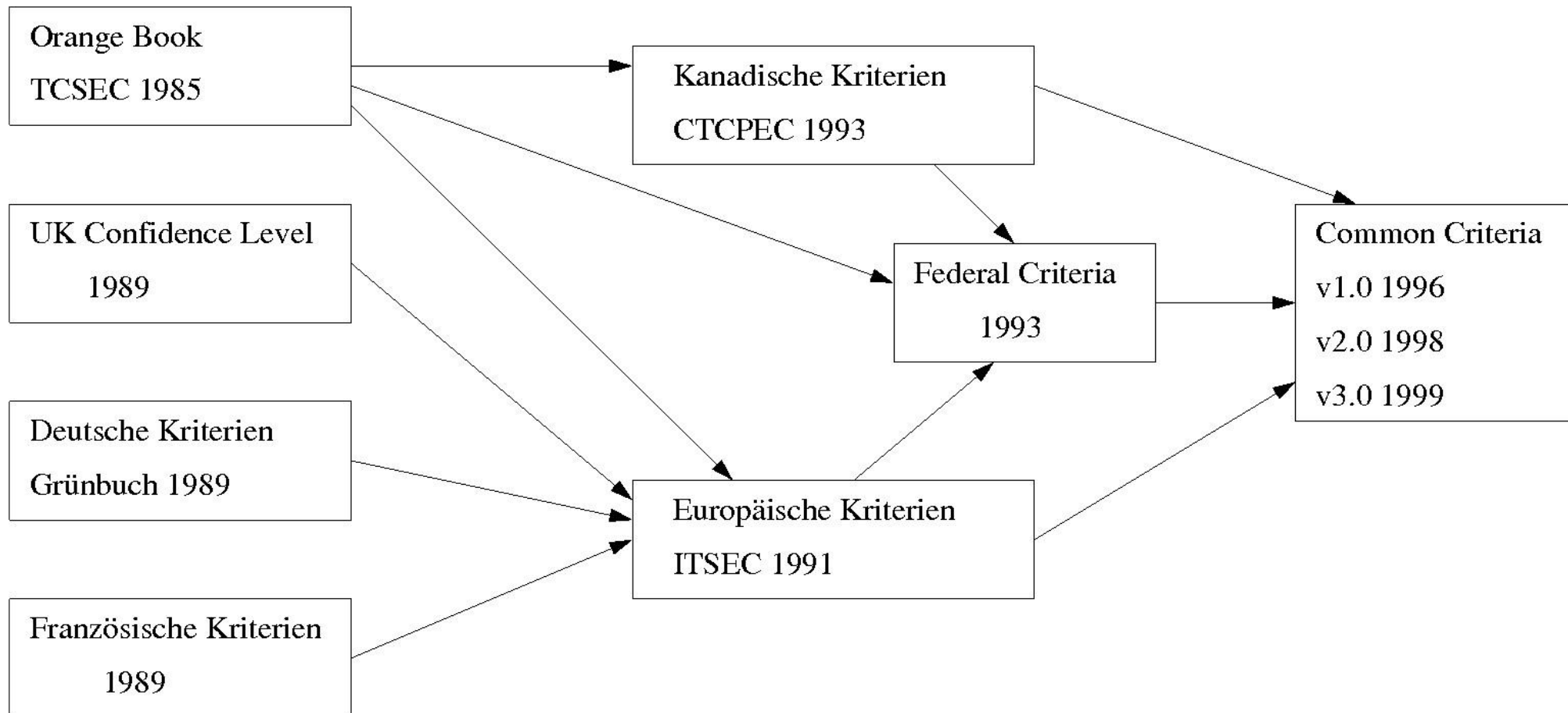
Ziele: Einheitliche Bewertungskataloge, Vergleichbarkeit

- Maßnahmenkatalog: Menge von Sicherheitsgrundfunktionen
- Qualität (der Realisierung):
z.B. getestet, ..., formal verifiziert
- Güte (der verwendeten Mechanismen):
ungeeignet, ..., unüberwindbar
- Bewertung durch unabhängige Stelle:
Evaluation und Zertifizierung, Beispiele für Zert.-Instanzen?
- Leitlinien für Hersteller bzw. Entwickler:
worauf ist zu achten
- Leitlinien für Anwender bei Produktwahl:
Vergleichbarkeit, ...

Bewertung der IT-Sicherheit Entwicklung

- Trusted Computer System Evaluation Criteria (Orange Book)
 - 1980 entwickelt
 - 4 Sicherheitsstufen (Hierarchie): (D < C1 < ... < B3 < A1)
 - fehlende Trennung zwischen Funktion und Qualität
- Deutsche IT-Kriterien (Grünbuch): 1989
 - Bewertung der eingesetzten Mechanismen: ungeeignet, schwach, mittel, stark, sehr stark, unüberwindbar
 - Funktionsklassen F1–F10
 - Qualitätsstufen Q0–Q7 (unzureichend - formal verifiziert)
- Europäische ITSEC-Kriterien
- Internationale Common Criteria (CC) for Information Technology Security Evaluation: seit 1996
(<https://www.commoncriteriaportal.org/>)

Bewertung der IT-Sicherheit Überblick



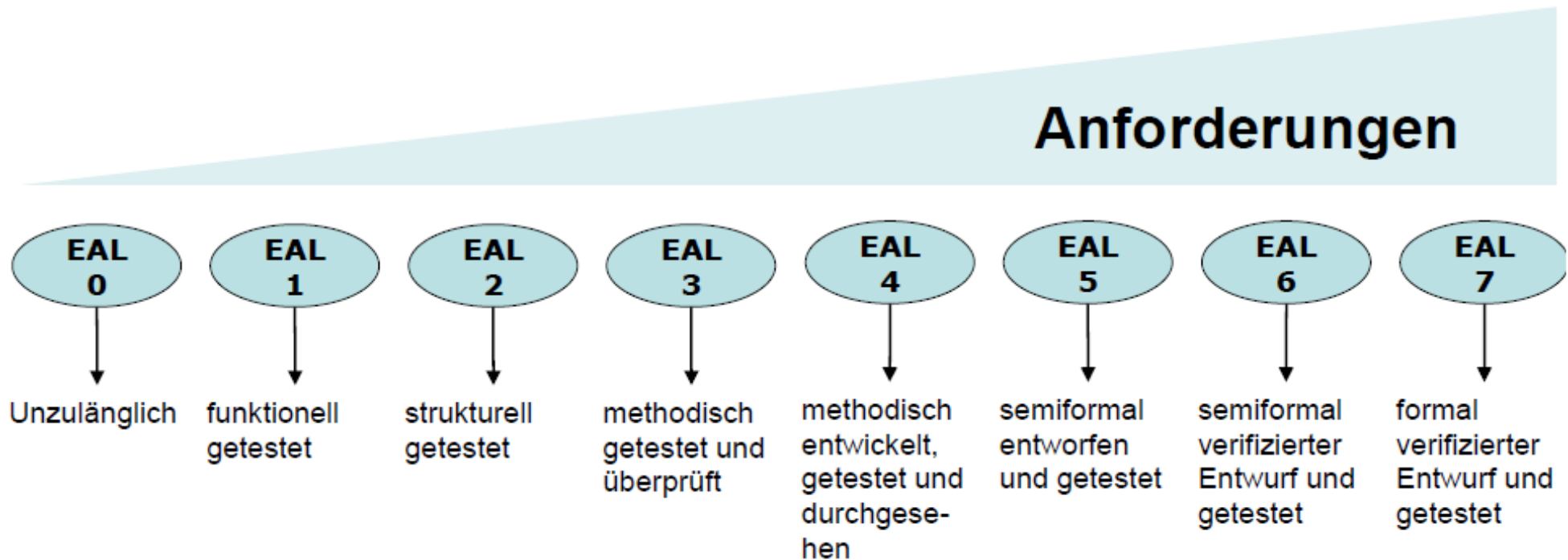
Bewertung der IT-Sicherheit: Common Criteria

- Target of Evaluation (TOE): IT-Produkt oder -System und die zugehörige Begleitdokumentation, die zu evaluieren sind. auf deutsch: **EVG: Evaluationsgegenstand**
- Security Target (ST): Menge von **Sicherheitsanforderungen**, die Grundlage der Evaluation eines TOE sind.
- Protection **Profile** (PP): Implementierungsunabhängige Menge von Sicherheitsanforderungen eines TOE.
- TOE Security Policy (TSP): **Regelwerk**, beschreibt, wie ein Asset im TOE verwaltet, geschützt und verteilt wird.
- TOE Security Function (TSF): Hardware, Software u. Firmware, die zur **Durchsetzung** der TSP benötigt werden.
- Evaluation Assurance Level (**EAL**): **Evaluationsstufe**

Bewertung der IT-Sicherheit: Common Criteria EAL

8 Evaluationsklassen EAL (Evaluation Assurance Level)

- **Beispiel:** RFID-Chip in nPA: EAL5 hoch zertifiziert



Bewertung der IT-Sicherheit: CC Funktionsklassen

- Funktionale Sicherheitsanforderungen sind strukturiert
- 11 Funktionsklassen mit funktionellen Familien
- Familien enthalten Komponenten
- Komponenten bestehen aus Elementen
- Beispiel: Klasse FIA - Identification and authentication
 - Enthält u.a. user authentication family (FIA_UAU)
 - FIA_UAU enthält u.a. Komponente Fälschungssichere Authentifizierung (FIA_UAU.3)
 - Element FIA_UAU.3.2 verhindert die Nutzung von kopierten Authentifizierungsdaten.

Bewertung der IT-Sicherheit: CC Funktionsklassen

- Komponente/Element einer Klasse definiert konkrete Anforderungen: z.B. Identifikation, Zugriffskontrolle, Beweissicherung
- Sicherheitsanforderungen spiegeln Best-Practice wider
- empfohlen zur Beschreibung der Funktionalität von Produkten bzw. Systemen
- **Klasse FIA:** Identification and authentication
- **Klasse FAU:** Security Audit:
Protokollieren und Analysieren sicherheitsrelevanter Events
- Weitere Klassen

Bewertung: CC Schutzprofile PP

Schutzprofile (Protection Profiles)

- anerkannte Lösung für Standard-Sicherheitsprobleme einer Produktgruppe, z.B. derzeit PP für Smart Meter
- implementierungsunabhängig,
- Verallgemeinerung der CC-Sicherheitsvorgaben
- PPs beschreiben ein Sicherheitskonzept

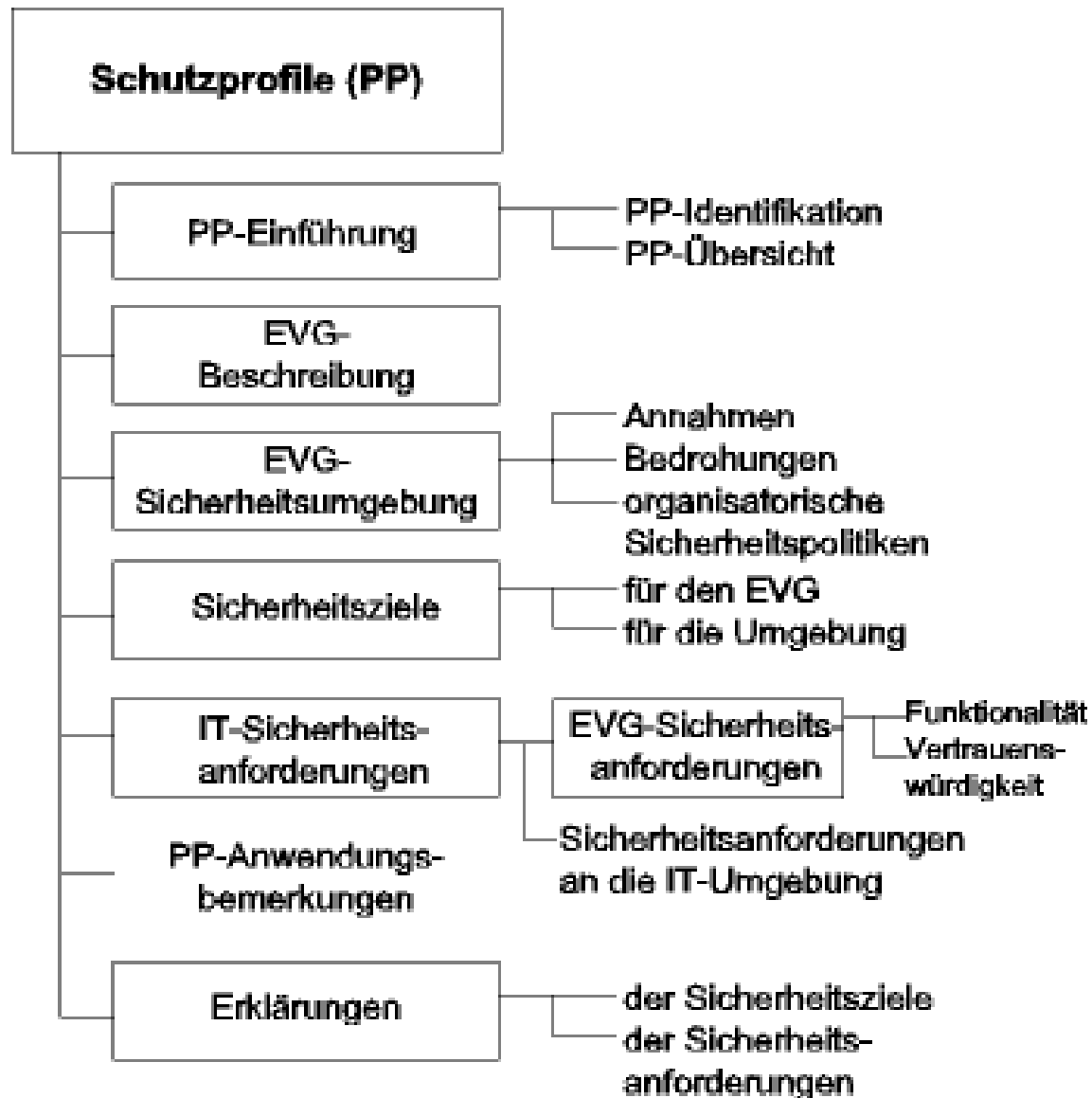
Anwender-Sicht:

- gute Vergleichbarkeit verschiedener Produkte, die auf Basis des Schutzprofils entwickelt und evaluiert wurden

IT-Hersteller-Sicht:

- erfolgreiche Evaluierung eines Schutzprofils bescheinigt, dass das PP ein sinnvolles, im Markt gewünschtes Konzept für ein IT-Sicherheitsprodukt darstellt

Bewertung: CC PP Aufbau



Bewertung: CC PP Aufbau

- **PP-Einführung:**

- eindeutige Identifikation und allgemeiner Überblick über das Schutzprofil **EVG-Beschreibung:**
- Beschreibung des EVG bzw. der Produktgruppe, auf die sich das Schutzprofil bezieht
- Einsatzmöglichkeiten, die allgemeinen IT-Sicherheitseigenschaften und Grenzen der Benutzung

- **EVG-Sicherheitsumgebung:**

- Beschreibung der Sicherheitsaspekte der beabsichtigten Einsatzumgebung und die erwartete Art der Nutzung des EVG

Bewertung: CC PP Aufbau

- **EVG-Sicherheitsumgebung (Forts.)**
 - Durchführung einer Art Risikoanalyse
 - Identifikation möglicher Angriffe und Schutzmethoden
 - Identifikation der Bedrohungen, denen nicht durch den EVG entgegengewirkt wird
 - organisatorische Sicherheitspolitiken: Annahmen über den sicheren Betrieb des EVG
- **Sicherheitsziele:**
 - Definition der Sicherheitsziele des EVG in seiner Einsatzumgebung
 - Angaben, wie den Bedrohungen entgegengewirkt wird bzw. die Sicherheitspolitiken erfüllt werden sollen

Bewertung: CC PP Aufbau

- **IT-Sicherheitsanforderungen:**
 - Definition der Anforderungen an die Funktionalität und an die Vertrauenswürdigkeit des EVG
 - Rückgriff auf die Anforderungen der Teile 2 und 3 der CC oder freie Formulierung
- **PP-Anwendungsbemerkungen:** optionale Informationen
- **Erklärungsteil des PP:**
 - Zeigen, dass ein zu diesem Schutzprofil konformer EVG eine wirksame Menge von IT-Sicherheitsmaßnahmen in seiner Sicherheitsumgebung bereitstellt: Sicherheitskonzept ist in sich schlüssig
 - Beziehungen zw. Sicherheitsumgebung, den Sicherheitszielen und den IT-Sicherheitsanforderungen werden beschrieben

Bewertung: CC Fazit

- 4-stufiger Prozess der Bewertung der Vertrauenswürdigkeit des Entwicklungsprozesses
 - Anforderungen, Architekturentwurf, Feinentwurf und Implementierung
- Wirksamkeit:
Eignung und Zusammenwirken der Funktionalität
 - Stärke der EVG-Sicherheitsfunktionen entspricht Mechanismenstärke: niedrig, mittel oder hoch
 - getrennte Prüfung und Bewertung der Funktionalität und der Vertrauenswürdigkeit.
- **Pros/Cons CC-Evaluierung?**

Bewertung: CC

- **Beispiele CC evaluierter Systeme?**
 - **SUSE Linux Enterprise Server Version 15**
(Version 12 war EAL4+)
 - **Microsoft Windows 11 and Windows Server 2022**
Protection Profile für Betriebssysteme
 - <https://www.commoncriteriaportal.org/>
 - (Nur) Zwei Produkte EAL7+
seit 16.7.2010 (aktualisiert 2023, zweites 2021)
Boundary Protection Devices and Systems

CC Statistik

1834 Certified Products by Category *		
Category	Products	Archived
Access Control Devices and Systems	22	139
Biometric Systems and Devices	2	3
Boundary Protection Devices and Systems	39	226
Data Protection	45	207
Databases	10	88
Detection Devices and Systems	6	75
ICs, Smart Cards and Smart Card-Related Devices and Systems	782	1455
Key Management Systems	5	53
Mobility	43	93
Multi-Function Devices	223	526
Network and Network-Related Devices and Systems	231	717
Operating Systems	40	210
Other Devices and Systems	321	845
Products for Digital Signatures	50	137
Trusted Computing	15	56
Totals:	1834	4830
Grand Total:		6664

CC Statistik II

Certified Products by Assurance Level and Certification Date												
EAL	2016	2017	2018	2019	2020	2021	2022	2023	2024	2025	2026	Total
Basic	0	0	0	0	0	4	13	15	8	4	9	53
EAL1	0	0	0	0	0	2	2	0	7	4	2	17
EAL1+	0	0	0	0	0	0	2	2	0	3	0	7
EAL2	0	0	0	0	1	18	12	14	14	14	15	88
EAL2+	0	0	0	0	0	15	30	33	21	31	11	141
EAL3	0	0	0	0	0	2	0	2	3	3	0	10
EAL3+	0	0	0	0	0	8	29	15	9	9	11	81
EAL4	0	0	1	0	1	2	2	3	1	5	2	17
EAL4+	1	1	1	1	2	46	52	89	59	80	45	377
EAL5	0	0	0	0	1	0	4	2	1	1	4	13
EAL5+	0	8	5	7	16	26	34	79	69	75	66	385
EAL6	0	0	0	0	0	0	1	1	0	0	0	2
EAL6+	0	0	0	0	2	21	31	33	49	33	9	178
EAL7	0	0	0	0	1	0	1	1	0	0	2	5
EAL7+	0	0	0	0	0	0	0	1	0	0	1	2
Medium	0	0	0	0	0	0	0	0	0	0	0	0
None	0	0	0	0	0	40	52	69	124	132	41	458
US Standard	0	0	0	0	0	0	0	0	0	0	0	0
Totals:	1	9	7	8	24	184	265	359	365	394	218	1834

CC Statistik III

Certified Products by Scheme and Assurance Level																			
Scheme	B	EAL1	EAL1+	EAL2	EAL2+	EAL3	EAL3+	EAL4	EAL4+	EAL5	EAL5+	EAL6	EAL6+	EAL7	EAL7+	M	N	S	Total
Australia	0	0	0	4	4	0	0	0	0	0	0	0	0	0	0	0	23	0	31
Canada	0	0	0	0	18	0	1	0	8	0	0	0	0	0	0	0	103	0	130
Germany	9	0	3	11	12	7	45	5	84	2	20	0	55	0	1	0	1	0	255
Spain	4	2	0	11	13	0	4	2	19	1	11	0	1	0	0	0	9	0	77
France	1	0	0	0	23	0	6	1	86	4	248	2	70	5	0	0	0	0	446
India	1	0	0	6	1	0	0	0	0	0	0	0	0	0	0	0	0	0	8
Italy	0	1	1	1	13	0	3	0	27	0	2	0	0	0	0	0	20	0	68
Japan	7	0	0	16	10	0	0	0	0	0	0	0	0	0	0	0	76	0	109
Republic of Korea	0	6	1	4	0	0	0	0	2	0	5	0	0	0	0	0	34	0	52
Malaysia	0	5	0	13	6	0	0	0	0	0	0	0	0	0	0	0	0	0	24
Netherlands	7	0	0	1	18	0	12	4	119	6	94	0	52	0	1	0	0	0	314
Norway	0	0	0	0	0	0	0	1	4	0	4	0	0	0	0	0	0	0	9
Poland	0	0	0	1	0	1	0	1	2	0	0	0	0	0	0	0	0	0	5
Qatar	0	1	0	1	0	0	0	0	0	0	0	0	0	0	0	0	0	0	2
Sweden	24	1	2	14	15	2	10	3	9	0	0	0	0	0	0	0	3	0	83
Singapore	0	1	0	2	8	0	0	0	9	0	0	0	0	0	0	0	0	0	20
Turkey	0	0	0	3	0	0	0	0	8	0	1	0	0	0	0	0	0	0	12
United States	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0	189	0	189
Totals:	53	17	7	88	141	10	81	17	377	13	385	2	178	5	2	0	458	0	1834